SENTINEL · ESSECKATHON TRACK 01 · FINTECH SECURITY · ÉQUIPE 2

Defense sheet

Un garde devant tout paiement d'agent IA : il vérifie l'autorité et l'intention, délivre un visa on-chain si OK, refuse et flague si c'est une arnaque, escalade à un humain en cas de doute. Chaque décision est une preuve inviolable sur Avalanche.

SentinelL1 Live | chainId 99999 | ERC-8004 + x402 | 2026-10-11

Scénario de menace traité

« a low-privilege agent, fed a booby-trapped document, tells a financial agent to execute a payment. Without authority-chain checks, it goes through. » (Track 01, problème 2)

Un agent peu privilégié, nourri d'un document piégé, ordonne un paiement à un agent financier. Sans vérification de la chaîne d'autorité, il passe. Cas réel Scamlexity : un agent de shopping achète sur un faux site et livre les données de paiement.

Vecteurs couverts : injection indirecte (HTML caché, PDF, mail), tool poisoning (MCP), confusion d'autorité, address poisoning, trésorerie migrée, encodage (base64 / hex / url / ROT13), homoglyphes, unicode invisible, dépassement de mandat, contrepartie frauduleuse (domaine neuf, marque sosie, honeypot).

Fonctions NIST CSF couvertes

Identify	Mandats et autorités résolus côté serveur, jamais déclarés par l'agent.
Protect	Visa on-chain à usage unique, GuardedVault fail-closed (pas de visa = revert).
Detect	7 couches de signaux + fusion Claude sur l'intention et l'injection.
Respond	Block + flag de l'adresse + escalade humaine, incident DORA ouvert au refus.
Recover	Trace on-chain rejouable, registre de menaces partagé et réutilisable.

ATT&CK / ATLAS & risques OWASP

`OWASP ASI03` Compromission d'autorité : un agent peu privilégié déclenche un paiement qu'il ne peut pas ordonner. Paré par la vérification de la chaîne d'autorité on-chain.

`OWASP ASI07` Abus d'agent ou d'outil : instruction injectée (document, page, autre agent) qui détourne l'outil de paiement. Paré par la détection d'injection.

`MITRE ATLAS` Prompt injection indirecte, évasion par encodage et obfuscation, manipulation d'agent.

`Vecteurs` HTML caché, PDF et mail piégé, tool poisoning (MCP), confusion d'autorité, address poisoning, trésorerie migrée, base64 / hex / url / ROT13, homoglyphes, unicode invisible, dépassement de mandat, contrepartie frauduleuse.

La parade : verify_payment. Pipeline pur et explicable, avant la signature : sanitisation (HTML caché, unicode invisible, blobs encodés), puis 7 couches de signaux (contenu, mandat, autorité on-chain, contrepartie, transaction, outils, comportement), blocs durs, fusion Claude sur l'intention, score de confiance dégressif, seuils `allow ≥ 70 · humain 30 à 70 · block < 30`. Le mandat est résolu côté serveur. Une adresse flaguée est refusée d'office la fois suivante.

Métriques atteintes (reproductibles)

100 %	**0 %**	**~1,4 ms**	**20 / 20**
Détection	Faux positifs	Temps de détection	Bout-en-bout on-chain
23 attaques + batterie 90/90	52 contrôles + batterie 10/10	médian, heuristiques ; ~3 s avec Claude	verdicts justes et minés

Limites connues

- Le jugement d'intention fin dépend de Claude ; sans LLM, on ne devine jamais allow (plancher humain).
- Chiffres mesurés sur notre banc (red-team + batterie + évasion) : honnêtes et reproductibles, mais pas une garantie universelle.
- La mémoire des menaces est on-chain et durable, mais le jugement reste par transaction (pas encore de corrélation multi-tx avancée).
- Un adversaire peut inventer une stratégie inédite : banc adaptatif testé (0 bypass), recalibrage continu, aucune triche.

SentinelL1 `chainId 99999` · SEC **AuthorityRegistry** `0x7A7e…bcb6` **GuardedVault** `0xc7de…C7c0` **API** `rpc.petroi.fr` **Explorer** `explorer.petroi.fr`

Ville 3D `city.petroi.fr`